

內部人員交易報表轉媒體儲存系統

系統架構與治理計畫書

PDF 閱讀版：含目錄與頁碼

文件來源	內部人員交易報表轉媒體儲存系統_系統架構與治理計畫書.md
產出位置	內部人員交易報表轉媒體儲存系統_系統架構與治理計畫書.pdf

目錄

內部人員交易報表轉媒體儲存系統	4
系統架構與治理計畫書 v1.4	4
1. 文件目的與設計原則	4
1.1 系統定位	4
1.2 範圍控制	4
1.3 審核後的修正優先順序	5
2. 系統架構	5
2.1 目標邏輯架構	6
2.2 最小可落地架構	7
3. 主要模組	7
3.1 Auth / Permission Module	7
3.2 Import Module	7
3.3 Validation Module	7
3.4 Report Module	8
3.5 Document Storage Module	8
3.6 Download Gateway / Watermark Module	8
3.7 Audit / Log / Alert Module	8
3.8 Admin Module	8
4. 資料流程	9
4.1 主流程	9
4.2 資料擷取	9
4.3 報表可重現性	9
4.4 Golden Dataset 與測試資料	10
5. 權限設計	11
5.1 身分驗證	11
5.2 角色與資料範圍	11
5.3 Admin 職責分離	12
5.4 權限代碼	12
6. PDF 儲存與浮水印處理方式	14
6.1 PDF 主檔保存	14
6.2 下載閘道	15

6.3 竄改偵測與外流追蹤	15
6.4 安全要求	16
7. 稽核、告警與穩定性	16
7.1 稽核範圍	16
7.2 Log 不得保存內容	17
7.3 告警分級	18
7.4 穩定性與一致性	18
7.5 非功能性需求基準	18
8. 資料模型摘要	19
附錄 A. 舊系統遷移策略	20
A.1 建議階段	21
Phase 0：盤點與測試基準	21
Phase 1：Shadow DB 與資料同步	21
Phase 2：報表雙製與 Snapshot 驗證	21
Phase 3：API 與服務邊界整理	21
Phase 4：Linux / Container 相容驗證	22
Phase 5：試營運與正式切換	22
A.2 Go / No-Go Gate	22
附錄 B. 資料量級與擴充策略	23
B.1 Level 1 初期量級	23
B.2 Level 2 成長量級	23
B.3 Level 3 大量級	24
附錄 C. 建議技術選型	24
附錄 D. 企業通用框架演進	24
附錄 E. Break-glass Protocol	25
附錄 F. 維護治理與 AI 協作準備	25
附錄 G. 主要風險、對策與驗收	26
G.1 主要風險與對策	26
G.2 驗收條件	26
附錄 H. Agent Team 協作與違規阻擋	27
結論	27

內部人員交易報表轉媒體儲存系統

系統架構與治理計畫書 v1.4

1. 文件目的與設計原則

本文件規劃一套用於證券商內部的「內部人員交易報表轉媒體儲存系統」。系統目標不是單純產生報表，而是將內部人員交易資料經由匯入、檢核、報表產生、PDF 媒體保存、浮水印、權限控管、下載闌道與稽核紀錄，形成可追蹤、可覆核、可保存、可逐步擴充的合規型報表保存平台。

本計畫以保守穩定遷移為核心，不追求一次到位改造。所有階段都必須可以驗證、可以回復、可以追蹤錯誤來源，並避免正式資料在測試環境中外流或被誤用。

本文件負責說明系統架構、主要模組、資料流程、權限設計、PDF 儲存與浮水印處理方式。實際可拆任務卡的功能項目與驗收條件，另見同目錄的「功能里程碑計畫」文件。

文件權威順序如下：

- 本文件是系統架構、治理原則、資料流程、權限模型、PDF 儲存與浮水印策略的 source of truth。
- Agent Team 協作、派工、review、違規阻擋與人類決策邊界，以《內部人員交易報表轉媒體儲存系統_Agent Team計畫書》v1.0 為 source of truth。
- 可拆任務卡的功能範圍、里程碑與驗收條件，以《功能里程碑計畫》與 [docs/ReportDemo/tasks/](#) 任務卡為準。
- 需要人類取舍或正式簽核的決策，以《決策紀錄樣板ADR》與實際 ADR 簽核結果為準。
- 跨版本異動摘要以《版本異動摘要ChangeLog》為索引，不取代上述任何一份 source of truth。

最高優先原則如下：

1. 資料安全
2. 權限管理
3. 系統穩定度

當功能便利性、開發速度、架構理想化與上述三項原則衝突時，應優先採用安全、可稽核、可回復的方案。

1.1 系統定位

本系統定位為「報表媒體化保存與下載管控平台」，不是交易主系統，也不是一般文件管理系統。它負責把已授權來源的交易、人員、部門、名單與檢核資料轉成正式報表，並保存報表主檔與可稽核的操作紀錄。

系統應具備以下能力：

- 整合 AD、LDAP、LDAPS、OIDC 或 SAML 等企業身分來源。
- 以 RBAC + Data Scope 控制報表、資料範圍、機密等級與操作權限。
- 報表主檔與下載副本分離，下載時不得直接提供 PDF 主檔。
- 所有敏感操作必須留下不可任意竄改的稽核紀錄。
- 支援資料量由初期數萬筆逐步擴充至百萬筆以上。
- 支援舊系統分階段遷移，並保留回復方案。

1.2 範圍控制

第一版採用類似馬斯克五步驟演算法的工程治理精神：先質疑需求、刪除不必要項目、再簡化與最佳化，最後才自動化。第一版不追求完整企業平台、微前端、Kubernetes、大型搜尋、全公司共用 SDK 或完整 AI 開發框架；這些可保留為後續演進，但不得成為第一版報表搬移的前置條件。

項目	第一版判斷	原因
Admin 角色管理	必須納入	沒有角色建立、授權與覆核，權限模型無法落地。
Golden Dataset / 報表比對	必須納入	是保守遷移與結果一致性的核心驗證工具。
Shadow DB	條件式納入	只在 DB 遷移驗證階段啟用，且不得影響正式結果。
Modular Monolith	必須納入	先清楚切 module，避免過早微服務化。
OpenSearch / Elasticsearch	延後	初期查詢量未必需要搜尋引擎，先用 DB 索引與分區。
Kubernetes / ArgoCD / Ceph	延後	屬企業部署平台，不應成為第一版報表搬移前置條件。
micro-frontend	刪除第一版	與報表搬移、稽核、安全無直接必要關係。

1.3 審核後的修正優先順序

為避免文件持續膨脹，本次修正只補強會影響落地成敗的前置關卡：

優先級	修正方向	原因
P0	稽核基礎、角色管理與 Data Scope 前置	匯入、查詢、下載與覆核都依賴稽核與權限，不應等到後段才建立。
P0	Phase 0 增加 DB、PDF、Object Storage、AD/OIDC PoC	避免 Linux、PDF library、DB 相容性到切換前才爆雷。
P0	上線 Gate 增加 NFR、Pilot、Rollback Window 與舊系統下線條件	保守遷移的重點是可驗證、可回復、可分批切換。
P1	Shadow DB 加入資安、隔離、容量與 DBA 維運評估	影子資料庫仍可能承載敏感資料，不可只當技術同步問題。
P1	Validation Rule、reason code、risk level 建立共同字典	減少各模組各說各話，提升稽核與比對可讀性。
P2	高機密安全預覽、PAM、session recording、PAdES-LTV 列為分級或決策點	重要但不應全部變成第一版硬需求。

2. 系統架構

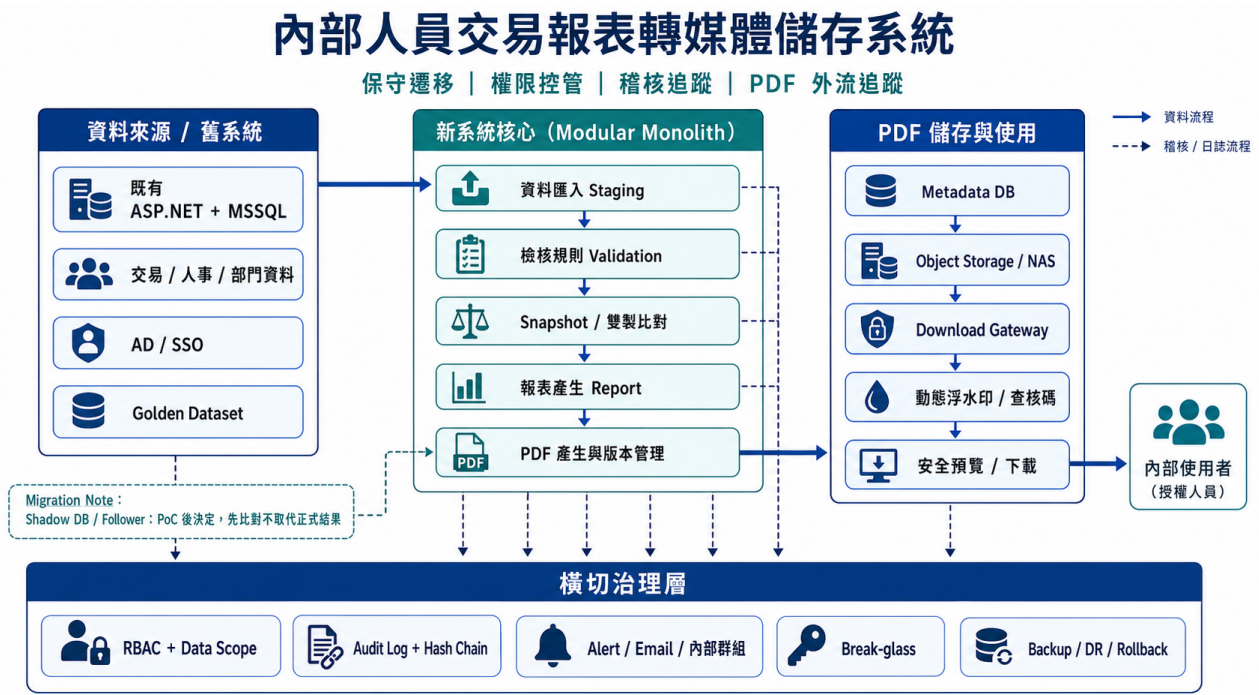


圖 1：系統架構溝通示意圖

2.1 目標邏輯架構

- 資料來源層
交易系統 / 人事系統 / AD / 部門資料 / 內部人名單
 - 資料擷取層
ETL / API Adapter / SFTP / Batch Import / Staging Table
 - 檢核與快照層
Validation Rule / Snapshot / Golden Dataset / Batch Summary
 - 報表產生層
Report Module / Template Version / Background Job
 - 文件保存層
Metadata DB / Object Storage or NAS / WORM Archive
 - 下載控管層
Permission Module / Download Gateway / Dynamic Watermark
 - 稽核與監控層
Audit Log / Structured Log / Alert / Trace
- 第一版建議採用 Modular Monolith 優先，將模組邊界切清楚，但不急著拆成多個獨立服務。報表產生、浮水印、稽核寫入可先以背景工作或同一應用內的 module 實作，等 Level 2 量級或效能瓶頸明確後再拆成獨立 worker。

2.2 最小可落地架構

ASP.NET Core Web/API
既有 MSSQL leader
PoC 選定的 Shadow DB / follower (僅在 DB 遷移驗證階段啟用)
Metadata DB
Object Storage / NAS
Report Module / Background Job
Download Gateway Module
Watermark Module
Audit Log
AD / OIDC 整合
Admin 角色管理
RBAC + 基礎 Data Scope
Golden Dataset
報表比對工具
Docker + 基礎 CI/CD

第一版不建議納入：

- 全面前後端重寫。
- 全系統一次切 Linux。
- 一開始就上 Kubernetes / ArgoCD / Ceph。
- micro-frontend。
- 全公司統一入口平台。
- OpenSearch / Elasticsearch。
- 完整 WORM / Immutable Archive 平台化。
- 完整 AI-ready 工程治理平台。
- 報表、浮水印、稽核一開始就全部拆成獨立微服務。
- 宣稱 PDF 可 100% 防竄改、防截圖或防破解。
- 未建立 Golden Dataset 前就切換正式資料庫。

3. 主要模組

3.1 Auth / Permission Module

負責使用者登入、AD / OIDC 整合、角色管理、功能權限、資料範圍授權與後端 API 授權檢查。前端顯示狀態不得作為授權依據。

3.2 Import Module

負責從交易系統、人事系統、部門資料、內部人名單或檔案來源匯入資料。所有資料需先進入 Staging 區，不可直接寫入正式報表資料表。

3.3 Validation Module

負責格式檢核、完整性檢核、邏輯檢核、重複檢核、名單檢核、禁止交易期間檢核、權責檢核與差異檢核。檢核規則不可全部寫死於程式碼，需具備版本管理與生效期間。

檢核結果等級如下：

等級	處理原則
Pass	可進入報表產生。
Warning	可產生報表，但需標記並納入覆核資訊。
Error	不可產生正式報表，需修正或退回。
Critical	批次中止並立即通知管理人員。

3.4 Report Module

負責報表模板版本、報表產生任務、報表重產、報表覆核與發布。每次報表產生必須有 Report Run ID，每份文件需有 Report ID / Report Version。

報表狀態機如下：

待產生
→ 產生中
→ 產生成功
→ 待覆核
→ 已覆核
→ 已發布
→ 已歸檔

例外狀態：

產生失敗 / 退回重產 / 重產中 / 已取代 / 作廢申請中 / 已作廢

3.5 Document Storage Module

負責 PDF 主檔 metadata、檔案儲存位置、版本、Hash、保存年限、作廢與封存策略。PDF 主檔是保存基準，不得因使用者下載而被修改。

3.6 Download Gateway / Watermark Module

負責下載授權檢查、下載序號、動態浮水印、下載副本 Hash、串流輸出與下載稽核。所有下載都必須經過下載閘道，不得直接提供 PDF 主檔或 Object Storage URL。

3.7 Audit / Log / Alert Module

負責稽核紀錄、結構化 log、告警分級、稽核查詢與稽核匯出。關鍵操作若稽核寫入失敗，應採 fail-closed。

3.8 Admin Module

負責系統參數、報表模板、浮水印政策、排程設定、角色管理、權限指派與 break-glass 核准。Admin 操作本身必須被稽核，且不得預設取得報表內容存取權。

4. 資料流程

4.1 主流程

資料來源
 → 資料擷取與 Staging
 → 資料檢核
 → 建立資料快照
 → 報表產生
 → PDF 主檔保存
 → 固定浮水印與 Hash
 → 覆核與發布
 → 查詢 / 預覽 / 下載
 → 動態浮水印
 → 稽核紀錄與告警
 → 重產 / 作廢 / 封存

4.2 資料擷取

編號	需求
DATA-001	每次資料擷取需產生唯一 Batch ID。
DATA-002	匯入資料需保存來源系統、來源檔名、來源筆數、匯入時間、匯入人員或排程 ID。
DATA-003	批次重跑需具備冪等性，不可造成重複交易資料。
DATA-004	每批資料需保存 checksum 或 hash。
DATA-005	匯入失敗需保留錯誤明細與可追蹤原因，不可覆蓋原始錯誤。

4.3 報表可重現性

每份報表必須能回答以下問題：

- 使用哪一批來源資料？
- 使用哪一版檢核規則？
- 使用哪一版報表模板？
- 使用哪一版人員、部門、內部人名單快照？
- 產生時的交易資料 Hash 為何？
- PDF 主檔 Hash 為何？
- 誰覆核、誰發布、誰下載？

Snapshot 至少包含：

Source Batch ID
 Validation Rule Version
 Report Template Version
 Employee / Department Snapshot Version
 Insider List Snapshot Version
 Trade Data Snapshot Hash
 Report Run ID
 PDF Master Hash

4.4 Golden Dataset 與測試資料

測試、開發、驗證環境不可使用未脫敏正式資料。若需要接近正式資料分布，應使用脫敏資料、合成資料、Golden Dataset 或受控的 shadow validation environment。

Golden Dataset 不是「把正式資料複製一份拿去測」。它是一組經過審核、可重複執行、已知預期結果的標準測試資料與標準報表基準，用於驗證匯入、檢核、報表產生、權限、浮水印、稽核與回歸測試。

類型	用途	是否可用正式資料
Golden Dataset	CI、回歸測試、報表基準、權限案例驗證。	不可使用未脫敏正式資料。
Production-like Dataset	SIT、效能測試、容量估算。	只能使用脫敏、遮罩或合成資料。
Shadow Validation Data	舊系統與新系統影子比對。	僅限受控驗證環境，需有權限、稽核與隔離。

Golden Dataset expected result 至少包含：匯入筆數與錯誤筆數、檢核 Pass / Warning / Error / Critical 結果、報表筆數與彙總金額、授權與未授權案例、PDF metadata、固定浮水印、動態浮水印與稽核紀錄預期結果。PDF 比對不應只依賴整份 PDF binary hash，應優先比對 canonical text、頁數、metadata、報表資料 Hash 與浮水印欄位。

5. 權限設計



5.1 身分驗證

系統需支援企業身分來源整合，初期建議以 AD / LDAPS / OIDC / SAML 擇一落地，並保留後續擴充。

編號	需求
AUTH-001	使用者登入必須透過企業身分來源或核准的 break-glass 帳號。
AUTH-002	後端 API 必須重新檢查權限，不可信任前端狀態。
AUTH-003	權限判斷需包含角色、部門、資料範圍、機密等級、報表狀態與來源 IP。
AUTH-004	高機密報表下載需支援二次確認、主管核准或額外覆核。

5.2 角色與資料範圍

權限模型需同時支援「固定預設角色」與「Admin 建立自訂角色」。預設角色用於降低初期複雜度，自訂角色用於因應部門、分公司、稽核與特殊作業需求。角色可以被建立、複製、停用、調整權限，但所有異動都必須經授權 Admin 操作並留下稽核紀錄。

系統權限分為兩層：

層級	用途
Role / Permission	控制使用者可執行哪些功能，例如查詢、預覽、下載、覆核、作廢、角色管理。
Data Scope	控制使用者可存取哪些資料範圍，例如部門、分公司、報表代號、機密等級、資料日期。

Role 不應直接代表資料範圍，Data Scope 也不應取代功能權限。兩者分離可以避免為每個部門與每個報表組合建立大量角色。

5.3 Admin 職責分離

Admin 權限不得設計成單一超級管理者無限制操作所有資料。系統需支援分工型 Admin 角色，且 Admin 預設不得下載或查看高機密報表內容，除非另有明確授權與稽核。

Admin 角色	主要職責	是否預設可看報表內容
System Admin	系統參數、排程、技術設定、服務狀態。	否
Permission Admin	建立角色、複製角色、停用角色、指派功能權限。	否
Security Admin	IP 白名單、安全參數、浮水印政策、告警設定。	否
Audit Admin / Auditor	查詢稽核紀錄、匯出稽核報告、覆核敏感操作。	依稽核權限與遮罩規則
Report Admin	報表模板、報表代號、報表作業流程設定。	依報表資料範圍
Break-glass Admin	核准緊急維修通道。	否，除非核准單明確授權

Admin 操作原則如下：

- 只有具備 `Role.Create` 或 `Role.Update` 權限的 Admin 可以建立或修改角色。
- 只有具備 `Role.Permission.Assign` 權限的 Admin 可以調整角色權限。
- 只有具備 `UserRole.Assign` 權限的 Admin 可以指派使用者角色。
- 只有具備 `DataScope.Assign` 權限的 Admin 可以調整資料範圍。
- Admin 不得核准自己提出的高風險權限異動。
- Permission Admin 不得授權自己取得更高權限，除非經另一位具備核准權限者覆核。
- 角色新增、權限異動、資料範圍異動都必須有申請、核准、生效時間與稽核紀錄。

5.4 權限代碼

建議權限代碼如下：

Report.Query
Report.Preview
Report.Download
Report.Generate
Report.Regenerate
Report.Void.Request
Report.Void.Approve
Report.Review
Report.Publish

Audit.Query
Audit.Export

Role.Query
Role.Create
Role.Update
Role.Disable
Role.Clone

Role.Permission.Assign
Role.Approve

UserRole.Assign
UserRole.Remove
DataScope.Assign

WatermarkPolicy.Update
SystemParameter.Update
Batch.Import
Batch.Rerun
BreakGlass.Request
BreakGlass.Approve

6. PDF 儲存與浮水印處理方式



6.2 下載閘道

下載時不得直接提供 PDF 主檔。所有下載都必須經過下載閘道。

使用者提出下載
 → 後端權限檢查
 → 產生 Download ID / Serial No.
 → 建立稽核紀錄
 → 讀取 PDF 主檔
 → 套用動態浮水印
 → 計算下載副本 Hash
 → 串流輸出
 → 更新下載完成紀錄

動態浮水印至少包含：

- 下載人姓名與帳號。
- 部門。
- 下載時間。
- 來源 IP。
- 下載序號。
- 報表代號與版本。

查核碼應隨下載副本產生；QR Code 是否顯示在 PDF 上，應依機密等級、報表類型與版面可讀性決定。QR Code 不得包含敏感明文，只能放查核碼或反查識別碼。

6.3 竄改偵測與外流追蹤

PDF 浮水印定位為「外流追蹤、嚇阻、竄改偵測與舉證輔助」，不得宣稱可 100% 防止竄改、截圖、翻拍、OCR 重製或人工重打。正確目標是提高移除成本、降低外流意願、留下追蹤線索，並讓正式 PDF 的完整性與來源可被驗證。

正式計畫書中應避免使用「PDF 防竄改」作為承諾，應改用以下表述：

竄改可偵測、外流可追蹤、責任可歸屬、證據可保存。

系統應採多層防護：

防護層	目的
可見動態浮水印	顯示下載人、部門、時間、IP、序號與報表版本。
QR Code / 查核碼	由外流文件反查下載紀錄；QR Code 依分級策略啟用，不強制套用於所有報表。
PDF 主檔 Hash	驗證系統保存主檔是否被異動。
下載副本 Hash	保存每次下載輸出的檔案指紋。
數位簽章與 timestamp	證明 PDF 自簽章後是否被修改，提供竄改偵測與舉證能力。
Flattening / 局部點陣化	對高機密報表提高移除浮水印成本，但不應全面套用。
PDF permission / encryption	作為輔助控制，限制一般編輯、複製或列印行為。
稽核紀錄	保存下載人、時間、IP、User-Agent、報表版本、下載序號。

機密等級建議策略：

機密等級	建議做法
一般內部報表	固定浮水印 + 動態浮水印 + 下載稽核。
機密報表	加 QR Code / 查核碼 + PDF 主檔 Hash + 下載副本 Hash。
高機密報表	加數位簽章 + timestamp + 局部 flattening。
極高機密報表	原則上不下載，只允許安全預覽、遮罩、限時、主管核准或 session recording。

Flattening / 點陣化不得全面套用，因為會增加檔案大小、降低文字搜尋與內容抽取能力、提高 CPU / 記憶體成本，並可能影響報表比對與可讀性。只有高機密或特殊核准報表才建議採局部處理。

6.4 安全要求

編號	需求
WM-001	動態浮水印只套用於下載副本，不得修改 PDF 主檔。
WM-002	若浮水印產生失敗，不得提供未加浮水印的 PDF。
WM-003	來源 IP 不可信任使用者端傳入值；若在 proxy 後方，只能信任指定 proxy 的 X-Forwarded-For。
WM-004	Object Storage bucket 不得公開，pre-signed URL 不得直接交給一般使用者。
WM-005	若保存下載副本，需加密、設定保存期限，並納入稽核控管。
WM-006	若使用數位簽章，需明確定位為竊改偵測與舉證，不得宣稱可阻止截圖、翻拍或重製。
WM-007	若使用 PDF permission / encryption，需定位為輔助限制，不得視為唯一安全邊界。

7. 稽核、告警與穩定性

7.1 稽核範圍

稽核寫入能力應在 M1 建立最小可用基礎，不應等到 M7 才導入。M7 的範圍應定位為稽核查詢、Hash Chain、告警分級與營運報表，而不是第一次開始寫入稽核紀錄。

以下操作必須留下稽核紀錄：

- 登入成功、登入失敗、登出、Session 逾時。
- 報表查詢、預覽、下載、下載失敗。
- 報表產生、重產、作廢、發布、退回。
- 資料匯入、檢核、重跑、例外處理。
- 角色、權限、資料範圍、AD 群組對應異動。
- 浮水印政策、保存年限、排程設定、IP 白名單異動。
- 權限不足、非法存取、異常下載、疑似暴力嘗試。
- break-glass 使用。

- 稽核查詢與稽核匯出。

每筆稽核紀錄至少包含：

```
audit_id
trace_id
correlation_id
event_time_utc
event_time_local
actor_user_id
actor_display_name
actor_department
actor_role_snapshot
source_ip
proxy_ip
user_agent
action
target_type
target_id
report_code
report_version
batch_id
data_date
result
reason_code
risk_level
before_hash
after_hash
request_hash
response_hash
pdf_hash
download_serial_no
previous_audit_hash
current_audit_hash
```

audit_log 不應把所有可能欄位都設為 mandatory。第一版可採「核心欄位 + event_payload_json + payload_hash」模式：登入、匯入、報表產生、下載、權限異動、break-glass 等事件共用核心欄位，事件特有資料放入 JSON payload，並以 payload_hash 保證內容可驗證。

reason_code、risk_level、action、result 必須建立共同字典，由業務、稽核、資安、維運與開發共同維護。Validation result、download result、admin approval、alert event 不得各自使用不同語意的狀態值。

Hash Chain 建議採「分範圍鏈」設計，例如依模組、資料表、事件類型或日期區間建立鏈結，並定期產生 root hash 封存。關鍵操作若稽核寫入或 Hash Chain 更新失敗，應採 fail-closed；一般查詢類事件可依風險等級進入 retry queue，但不得靜默遺失。

7.2 Log 不得保存內容

Log 與稽核紀錄不得保存以下內容：

- 密碼、Access Token、Refresh Token。
- Session ID 原文。
- DB connection string。
- encryption key、private key、API key。
- 完整身分證號、完整金融帳號。
- 未遮罩的完整交易敏感欄位。

7.3 告警分級

等級	事件範例	通報方式
Critical	高機密報表未授權下載、PDF 主檔 Hash 不符、稽核寫入失敗、批次重大錯誤、break-glass 使用	內部即時群組 + Email + 值班通知
Error	報表產生失敗、匯入失敗、下載開道錯誤、權限同步失敗	Email + 工單
Warning	異常下載頻率、資料差異偏高、檢核警示	每日報表 + 管理後台提示
Info	一般查詢、一般下載、一般排程完成	留存查詢

7.4 穩定性與一致性

系統需避免以下高風險狀況：

- 報表產生到一半失敗卻標記成功。
- PDF 已保存但 metadata 未寫入。
- metadata 已寫入但 PDF 不存在。
- 使用者下載到未加浮水印 PDF。
- 權限異動成功但未留下稽核。
- 重產覆蓋舊版報表。
- 批次重跑造成重複資料。
- 稽核紀錄與業務操作不一致。

編號	需求
STAB-001	報表產生需有明確狀態機。
STAB-002	PDF 保存與 metadata 更新需具備補償機制。
STAB-003	批次作業需支援中斷續跑。
STAB-004	背景任務需具備 retry 與 dead-letter queue。
STAB-005	下載流程若任一步驟失敗，不可回傳未完成檔案。
STAB-006	多節點排程需避免重複執行，可採 leader election 或分散式鎖。
STAB-007	關鍵任務需具備 trace ID，方便跨服務追蹤。
STAB-008	匯入、報表產生、PDF 輸出、下載與 worker 任務需具備 idempotency key，避免重試造成重複資料或重複報表。

7.5 非功能性需求基準

第一版不應過早承諾未經量測的高規格 SLA，但需要設定可驗收的最低基準，並於 Phase 0 PoC 後修正數值。

項目	第一版基準
可用性	月可用性目標 99.5%，排除預先公告維護窗。
RPO	metadata DB 與稽核資料 RPO 15 分鐘以內，實際值需與公司備份政策對齊。
RTO	第一版 RTO 4 小時以內，正式切換前需完成演練。
批次完成時間	以舊系統同批次時間為基準，Phase 0 建立 baseline 後設定可接受上限。
下載延遲	一般報表下載需在可接受互動時間內完成；高機密報表若啟用簽章或局部點陣化，可另訂門檻。
告警時效	Critical 事件 5 分鐘內送達內部即時群組與 Email。
錯誤率	正式切換前需連續觀察，重大批次錯誤率與下載錯誤率低於 Go / No-Go Gate 門檻。

8. 資料模型摘要

主要資料表建議如下：

表格	用途
source_system	資料來源定義。
import_batch	匯入批次。
import_batch_detail	匯入明細與錯誤。
insider_person	內部人員主檔。
employee_snapshot	員工與部門快照。
trade_staging	交易暫存資料。
trade_normalized	正式交易資料。
validation_rule	檢核規則。
validation_result	檢核結果。
report_template	報表模板。
report_template_version	報表模板版本。
report_run	報表產生任務。
report_document	報表 metadata。
report_document_version	報表版本。
document_storage_ref	PDF 儲存位置與 Hash。
download_request	下載請求。
download_record	下載紀錄與序號。
watermark_policy	浮水印政策。

表格	用途
role	角色定義，包含系統預設角色與 Admin 建立的自訂角色。
permission	功能權限定義。
role_permission	角色與功能權限對應。
user_role	使用者與角色對應。
ad_group_role_mapping	AD 群組與系統角色對應。
data_scope_policy	資料範圍授權政策。
user_data_scope	使用者或角色的資料範圍授權。
role_change_request	角色或權限異動申請。
role_change_approval	角色或權限異動核准紀錄。
audit_log	稽核紀錄。
system_parameter	系統參數。

大量級時建議分區：

- trade_normalized 依 data_date 月分區。
- report_document 依 data_date 或 created_at 月分區。
- audit_log 依 event_time 月分區。
- download_record 依 download_time 月分區。

附錄 A. 舊系統遷移策略

既有 ASP.NET / MSSQL 系統若目前仍承載正式報表，不建議一開始就拆出 server 端邏輯或直接改寫 stored procedure。這會讓新舊系統結果難以驗證，也會使問題難以定位。

建議採用「Shadow Migration + 報表雙製比對 + 分階段切換」。

本附錄只定義遷移治理路線；實際功能工作拆分以「功能里程碑計畫」為準。兩份文件的對應如下：

遷移階段	對應功能里程碑	關係
Phase 0：盤點、PoC 與測試基準	M0	先建立舊系統覆蓋範圍、Golden Dataset、SP 分類、DB/PDF/AD/Object Storage PoC 與 RACI。
Phase 1：Shadow DB、Staging 與稽核基礎	M1、M9-01	先讓新資料路徑可接收、比對、稽核與回復，不影響正式結果。
Phase 2：檢核、報表、PDF 與下載閘道	M2、M3、M4、M5	檢核、報表、PDF 與下載功能需搭配 Data Scope、Snapshot 與舊系統比對。
Phase 3：查詢、覆核、Admin 與營運稽核	M6、M7、M8	查詢、預覽、覆核、稽核查詢與 break-glass 逐步模組化。
Phase 4：Linux / Container 相容驗證	M9-02、M9-03	以技術驗證、UAT、訓練與回復演練作為切換前條件。

遷移階段	對應功能里程碑	關係
Phase 5：Pilot、分批切換與正式驗收	M9-04、M9-05、M10	以 Pilot、Rollback Window、NFR、權限、稽核、PDF 與舊系統覆蓋作為正式切換 Gate。

A.1 建議階段

Phase 0：盤點與測試基準

- 盤點 table、view、stored procedure、trigger、排程、報表模板。
- 盤點 Windows-only library、PDF 產生依賴、字型、GDI、檔案路徑。
- 盤點 AD、權限、稽核、下載與覆核流程。
- 將 stored procedure、view、trigger、batch job 分類為保留、封裝、重寫或淘汰。
- 執行 PDF library Linux PoC，確認浮水印、簽章、字型、中文、PDF/A 或長期驗證需求可行。
- 執行 DB 選型 PoC，不預設 MariaDB 一定適合；需比較 MSSQL on Linux、PostgreSQL、MariaDB 與原 MSSQL 相容性。
- 執行 Object Storage / NAS、AD / OIDC、備份還原與權限隔離 PoC。
- 建立 Golden Dataset，不使用未脫敏正式資料，並同步建立 expected result、資料血緣、維護責任與核准紀錄。
- 建立新舊報表比對工具。

Phase 1：Shadow DB 與資料同步

- 保留 MSSQL 作為正式 leader。
- 建立經 PoC 選定的 Shadow DB / follower。
- 透過 CDC、ETL、Outbox 或批次同步將資料寫入 Shadow DB。
- Shadow DB 只做比對與驗證，不影響正式報表結果。
- 建立 DLQ 與同步錯誤追蹤。
- Shadow DB 必須定義網段隔離、DB 權限、加密、備份、資料保留、存取稽核與 DBA 維運責任。
- Shadow DB 容量需納入 CPU、RAM、IOPS、NAS/Object Storage、備份窗口與同步延遲評估。

Phase 2：報表雙製與 Snapshot 驗證

- 同一批 Golden Dataset 同時在舊系統與新流程產生報表。
- 比對筆數、金額、欄位、排序、頁數、PDF metadata、文字摘要與 Hash。
- Phase 2 的 PDF baseline 需同時確認 Linux Container 產出可行；若 Windows 與 Linux 產出差異無法解釋，不得把 PDF 驗證留到 Phase 4 才處理。
- 建立 Snapshot：來源批次、規則版本、模板版本、人員部門版本、內部人名單版本、交易資料 Hash。
- 建立每日差異報表與人工覆核流程。

Phase 3：API 與服務邊界整理

- 優先抽出低風險讀取 API 或 Adapter。
- 權限判斷集中於 Permission Module 或共用授權元件。
- 不一次重寫所有 stored procedure；高風險邏輯先保留並以比對驗證替代。
- 逐步將報表產生、下載浮水印、批次匯入拆為 service / worker。

Phase 4：Linux / Container 相容驗證

- 驗證 PDF library 支援 Linux、中文字型、逐頁浮水印、數位簽章。
- 驗證 AD / LDAPS / OIDC 連線。
- 驗證時區、路徑、檔案權限、Object Storage、備份還原。
- 建立 Dockerfile、CI/CD、rollback runbook。
- 初期可先 Docker 化，不必強制導入 Kubernetes。

Phase 5：試營運與正式切換

- 先導入非正式報表。
- 再導入低機密報表。
- 最後導入高機密正式報表。
- 切換前凍結資料異動，執行最終同步與 checksum 比對。
- 啟用監控、告警與 rollback window。
- 切換需採 Pilot / 分批 / 分部門或分報表等級方式，不得一次全量切換。
- MSSQL leader 下線需另設 Gate：連續 N 批次或 N 天雙製比對通過、重大錯誤率低於門檻、Rollback Window 結束、業務、稽核、資安與維運共同簽核。

A.2 Go / No-Go Gate

Gate	通過條件
資料比對	Golden Dataset expected result 與抽樣批次比對通過。
報表比對	筆數、金額、頁數、排序、模板版本、PDF metadata 通過。
權限測試	RBAC / Data Scope / 高機密 / 無權限案例通過。
稽核測試	敏感操作、稽核查詢、稽核匯出均有紀錄。
PDF 安全	主檔不可直接下載，動態浮水印、Hash、竄改偵測與外流追蹤通過。
效能測試	批次匯入、報表產生、下載尖峰達標。
NFR 測試	RPO、RTO、批次完成時間、下載延遲、告警時效與錯誤率達標或有核准例外。
DR 演練	備份還原、Object Storage 回復、rollback runbook 通過。
Pilot 驗收	先導報表或低機密報表試營運完成，問題均有處置紀錄。
人工簽核	業務、稽核、資訊安全、系統維運共同核准。

附錄 B. 資料量級與擴充策略

B.1 Level 1 初期量級

項目	規模
每日交易資料	1 萬至 5 萬筆
每月 PDF 報表	1,000 至 5,000 份
使用者	100 至 300 人
同時在線	20 至 50 人
資料庫容量	100GB 以內
PDF 儲存	1TB 以內

建議作法：

- ASP.NET Core Web/API。
- 既有 MSSQL leader + PoC 選定的 Shadow DB / follower。
- NAS 或 S3-compatible Object Storage。
- 背景服務處理匯入、報表產生與浮水印。
- 稽核紀錄與主資料庫可先同 DB 不同 schema / table，但權限需隔離。

B.2 Level 2 成長量級

項目	規模
每日交易資料	5 萬至 100 萬筆
每月 PDF 報表	5,000 至 50,000 份
使用者	300 至 2,000 人
同時在線	100 至 300 人
資料庫容量	100GB 至 2TB
PDF 儲存	1TB 至 20TB

建議作法：

- Web/API 無狀態化。
- 報表、匯入、檢核、浮水印、稽核 worker 化。
- 使用 Message Queue 分派任務。
- DB 依 data_date、batch_id、report_code 分區。
- 查詢與稽核查詢使用 read replica。
- 稽核紀錄逐步獨立儲存。

B.3 Level 3 大量級

Level 3 屬後續演進，不應成為第一版前置條件。若每日交易資料達 100 萬筆以上、每月 PDF 50,000 份以上，才評估分庫、搜尋索引、冷儲存、非同步下載與完整 worker pool。

附錄 C. 建議技術選型

若延續 C# 技術棧，建議如下：

層級	建議
Backend	ASP.NET Core 10 LTS；若既有套件限制，可短期使用 .NET 8 過渡。
API	REST API / Controller / Minimal API。
Background Job	.NET Worker Service。
DB	MSSQL leader 過渡，Shadow DB 需經 PoC 選定；候選包含 MSSQL on Linux、PostgreSQL、MariaDB。
ORM	EF Core 或 Dapper；provider 需依最終 DB 選型確認。
Queue	RabbitMQ / Kafka / Redis Stream。
PDF	iText for .NET、QuestPDF、Syncfusion PDF 或經驗證可跑 Linux 的商用 PDF SDK。
Object Storage	MinIO / S3-compatible storage / 企業 NAS。
Authentication	AD / LDAPS / OIDC / SAML。
Reverse Proxy	Nginx / HAProxy。
Container	Docker；成長期再評估 Kubernetes / OpenShift。
Log	Serilog / OpenTelemetry。
Monitoring	Prometheus / Grafana / ELK / OpenSearch。

技術選型原則：

- Backend 採「目前受支援的 .NET LTS」策略；截至 2026-07-02，.NET 10 已為 LTS Active，應優先評估 .NET 10，只有在企業基準、既有套件、相容性或維運限制未解除時，才短期以 .NET 8 過渡，並設定升級時程。
- PDF library 必須支援 Linux。
- PDF library 必須支援中文嵌入字型、逐頁浮水印與主檔 Hash。
- 不應依賴 Windows GDI+。
- 權限判斷需集中化，不可散落在各 controller。
- 稽核寫入需標準化，不可由各功能自由組字串。
- Secret 不可放在程式碼或明文設定檔，應使用 Vault、KMS 或企業 Secret Manager。

附錄 D. 企業通用框架演進

若公司內有數百個類似舊系統，應將本系統設計成可逐步接軌企業共用框架，而不是第一版就承擔全部平台化責任。

共用能力	本系統第一版做法	企業化演進
身分驗證	AD / OIDC 整合	統一 SSO 與身份治理
權限判斷	Permission Module / 共用授權模組	企業權限中心
稽核	Structured Audit Log	統一 Audit SDK / Audit Platform
PDF 浮水印	系統內 Watermark Module	共用 PDF Watermark SDK
下載控管	Download Gateway	企業文件下載閘道
部署	Docker + CI/CD	Kubernetes / GitOps / ArgoCD
監控告警	Log + Metrics + Alert	統一 Observability Platform
緊急維修	break-glass protocol	企業級 PAM / session recording
維護文件與測試	規格、OpenAPI、測試資料、回歸測試	AI-ready 工程治理標準

附錄 E. Break-glass Protocol

緊急維修通道必須存在，但必須受到更嚴格控管。

編號	需求
BG-001	break-glass 帳號需事前核准、限時啟用、使用後自動失效。
BG-002	使用時必須填寫原因、事件編號與預期處理範圍。
BG-003	所有 SQL、shell command、檔案操作、來源 IP、時間、結果都需稽核。
BG-004	Critical 通報需即時送出。
BG-005	事後需由稽核或主管覆核操作內容。
BG-006	啟用需採 dual-control 核准，並要求 MFA / OTP 或等效強驗證。
BG-007	權限需以限時、限範圍 token 或臨時角色授權，不得長期持有高權限帳號。
BG-008	高風險維修應評估 PAM vault 與 session recording；若第一版不導入，需列為 Level 2 或高機密場景決策項。

附錄 F. 維護治理與 AI 協作準備

本系統應支援多人與多 AI 介入開發、維修與審查，但 AI 不應直接繞過人類決策。

第一版要求如下：

- API 必須有 OpenAPI 規格。
- DB schema 與 migration 需版本化。
- 權限規則、浮水印政策、報表模板、檢核規則需可追蹤版本。
- Golden Dataset regression test 必須納入 CI。

- CI/CD 至少需包含單元測試、報表比對、權限測試與基本 dependency scan。
- 高風險變更需人類 code review 與上線簽核。
- Feature Flag 只能用於安全可控的切換，不得用來繞過稽核或權限。
- AI 產生的修改需保留決策理由、測試證據與人工覆核紀錄。

延後項目如下：

- 完整 AI 開發代理治理平台。
- 自動派工與自動上線決策。
- 大型全公司共用工程 SDK。
- 全面 SAST / DAST / policy-as-code 平台化。

附錄 G. 主要風險、對策與驗收

G.1 主要風險與對策

風險	對策
新舊系統報表結果不一致	Golden Dataset、雙製報表、差異報表、人工覆核。
DB 遷移語法與語意差異	DB 選型 PoC、Shadow DB、分階段 SQL 改寫、row hash、資料比對。
PDF 浮水印被移除或截圖外流	動態浮水印、下載序號、QR 查核碼、Hash、數位簽章、稽核追蹤。
metadata 與 PDF 主檔不同步	狀態機、補償機制、Hash 檢查、背景 reconciliation。
權限判斷分散造成漏洞	Permission Module、後端強制授權、權限測試。
稽核紀錄遭修改	append-only、Hash Chain、權限隔離、WORM 封存。
批次重跑造成重複資料	Batch ID、冪等設計、唯一鍵、重跑策略。
過早平台化導致計畫失控	第一版聚焦報表搬移，平台能力列入成長期。

G.2 驗收條件

系統驗收至少包含：

- Golden Dataset 全案例與 expected result 比對通過。
- 新舊報表雙製比對通過。
- PDF 主檔 Hash 與下載副本 Hash 可追蹤。
- 未授權使用者無法查詢、預覽、下載報表。
- 高機密報表下載需通過額外控管。
- 稽核紀錄完整，且稽核查詢本身有紀錄。
- Critical 事件能在 5 分鐘內通報。
- 批次重跑不會產生重複資料。
- 報表重產不覆蓋舊版。
- 作廢流程需覆核並保留歷史。

- 備份還原與 rollback runbook 演練通過。

附錄 H. Agent Team 協作與違規阻擋

Agent Team 的最新協作規則以《內部人員交易報表轉媒體儲存系統_Agent Team計畫書》v1.0 為準。本文件僅保留架構治理角度的摘要，避免兩份文件各自演進。

第一版應採用下列原則：

- Captain / Coordinator 可協助拆工、派工、排序、風險升級與 review routing，但不得自行覆蓋資安、稽核、資料治理、正式切換或 ADR 要求。
- 任務卡必須標示 Agent role、reviewer、validator、human sign-off 與 ADR gate；M5、M7、M8、M9 類任務需額外檢查 Security / Audit / QA 角色是否納入。
- Agent 可自動處理低風險、可回復、已有規則的執行決策；涉及 DB 選型、SSO/API session、PDF library、Object Storage/WORM、Golden Dataset 正式資料邊界、權限模型、稽核 fail-closed、Pilot、Go/No-Go 或舊系統下線者，必須人類或 ADR 簽核。
- 違規阻擋不能只依賴 Agent 自律，需透過任務卡 scope、Permission Broker 概念、lease/fencing、tool sandbox、validator/reviewer 與 closure gate 共同實現。
- 第一版若 runtime 阻擋尚未完整落地，至少需以人工 review、CI scope check、command-backed evidence、closure checklist 與人類簽核補位。

結論

本系統應以「保守穩定、可驗證、可稽核、可回復」作為核心，不應把舊系統搬移包裝成一次到位的平台重建。

最穩妥的路線是先建立 Golden Dataset 與報表比對基準，再以經 PoC 選定的 Shadow DB / follower 驗證資料與報表一致性；確認報表、權限、稽核與 PDF 安全流程都通過後，再逐步拆分 API、worker、Linux/container 與企業共用框架。

對證券商情境而言，本計畫成功與否不只取決於功能是否做完，而是取決於系統是否能在大量交易資料、嚴格權限控管、稽核追蹤、PDF 外流風險與正式上線回復壓力下保持穩定且可證明。